

Modelo de Encuesta Integral sobre Indicadores y Métricas SIEM

Versión 1.0 – Kit de encuesta para responsables de ciberseguridad, riesgo, cumplimiento y tecnología en organizaciones españolas y multinacionales con operaciones en España.

0. Instrucciones para la persona encuestada

Esta encuesta pretende captar, sin anestesia pero con cariño, el grado real de implantación, calidad y uso estratégico de su plataforma SIEM y del ecosistema de monitorización asociado. No buscamos respuestas “perfectas”, sino un mapa honesto de dónde está su organización hoy.

Salvo que se indique lo contrario:

- Responda pensando en el ámbito organizativo bajo su responsabilidad (grupo, país, sector público/privado, etc.).
- Cuando se ofrezcan escalas de madurez (0–5), utilice:
- 0 = No existe / No se aplica
- 1 = Muy incipiente, informal o experimental
- 2 = Parcial, en pocas áreas / sin estandarizar
- 3 = Definido y aplicado de forma mayoritaria
- 4 = Integrado, medido y mejorado regularmente
- 5 = Optimizado, con automatización y mejora continua

1. Perfil de la organización y del encuestado

1.1 Tipo de organización

- ☐ Administración pública – AGE
- ☐ Administración pública – Autonómica
- ☐ Administración pública – Local / Diputación / Cabildo
- ☐ Operador de servicios esenciales (NIS2)
- ☐ Operador de servicios importantes (NIS2)
- ☐ Entidad financiera / aseguradora
- ☐ Energía / utilities (electricidad, gas, agua, etc.)
- ☐ Transporte y logística
- ☐ Sanidad
- ☐ Educación / Investigación
- ☐ Industria / manufactura
- ☐ Telecomunicaciones / 5G
- ☐ Tecnología / servicios digitales
- ☐ Otro (especificar): _____

1.2 Ámbito geográfico principal de operación

- ☐ España
- ☐ España + otros países UE

- ☐ Global (incluye UE)
- ☐ Otro (especificar): _____

1.3 Tamaño aproximado de la organización (empleados/as)

- ☐ < 250
- ☐ 250–999
- ☐ 1.000–4.999
- ☐ 5.000–19.999
- ☐ ≥ 20.000

1.4 Rol principal del encuestado

- ☐ CISO / Responsable global de ciberseguridad
- ☐ Responsable de SOC / CSIRT
- ☐ Responsable de TI / Infraestructura
- ☐ Responsable de Riesgos / Cumplimiento / Auditoría
- ☐ Responsable de OT / ICS
- ☐ Responsable de negocio (no técnico)
- ☐ Otro (especificar): _____

1.5 ¿Dispone la organización de SOC propio, híbrido o externalizado?

- ☐ SOC interno 24x7
- ☐ SOC interno horario extendido (no 24x7)
- ☐ SOC híbrido (interno + proveedor)
- ☐ SOC externalizado / MSSP
- ☐ No disponemos de SOC formal, pero sí de capacidades de monitorización
- ☐ No disponemos de SOC ni capacidades formales de monitorización

2. Arquitectura y alcance del SIEM

2.1 ¿Dispone su organización de una plataforma SIEM en producción?

- ☐ Sí, único SIEM corporativo
- ☐ Sí, varios SIEM (por regiones / BU / entornos IT-OT separados)
- ☐ En fase de implantación / proyecto
- ☐ Actualmente no, pero está planificado
- ☐ No, ni se le espera (de momento)

2.2 Tipo de solución SIEM predominante

- ☐ On-premises tradicional
- ☐ Cloud-native (SaaS / PaaS)
- ☐ Modelo híbrido (on-prem + cloud)
- ☐ Otro (especificar): _____

2.3 Cobertura de fuentes de logs y telemetría (marque todo lo que aplique)

- ☐ Infraestructura de red (firewalls, routers, switches, proxies, VPN, etc.)

- ☐ Sistemas operativos (Windows, Linux, Unix)
- ☐ Directorio / identidad (AD, LDAP, IdPs, etc.)
- ☐ Aplicaciones de negocio críticas (ERP, core bancario, historia clínica, etc.)
- ☐ Servicios cloud (IaaS, PaaS, SaaS principales)
- ☐ Endpoints (EDR/XDR, AV, MDM, etc.)
- ☐ Sistemas OT / ICS / SCADA
- ☐ Dispositivos IoT / IIoT
- ☐ Herramientas de seguridad (WAF, DLP, CASB, etc.)
- ☐ Sistemas de ticketing / ITSM
- ☐ No lo sabemos con precisión
- ☐ Otro (especificar): _____

2.4 ¿Qué porcentaje aproximado de los activos clasificados como críticos envía logs relevantes al SIEM?

- ☐ 0–20 %
- ☐ 21–40 %
- ☐ 41–60 %
- ☐ 61–80 %
- ☐ 81–95 %
- ☐ > 95 %
- ☐ Desconocido / no medido

2.5 Nivel de normalización y calidad de los datos en el SIEM (escala 0–5)

Califique del 0 al 5:

- Coherencia de formatos de timestamp: _
- **Consistencia de campos críticos (IP, usuario, host, etc.):**
- *Gestión de fallos de parsing / eventos “indigeribles”:* _
- *Existencia de un modelo de datos común (schema, taxonomías) documentado:*

2.6 ¿Monitorea el SIEM también eventos de identidad y acceso en un contexto de Zero Trust?

- ☐ Sí, de forma sistemática (autenticaciones, autorizaciones, MFA, anomalías, etc.)
- ☐ Parcialmente, para algunas aplicaciones / entornos
- ☐ Muy limitado o inexistente
- ☐ Desconocido

3. Indicadores operativos: velocidad, calidad, cobertura

3.1 Velocidad (MTTD, MTTR, etc.)

3.1.1 ¿Mide formalmente su organización el MTTD (Mean Time To Detect) de incidentes de seguridad?

- ☐ Sí, de forma sistemática y con objetivos definidos
- ☐ Sí, pero de forma ad-hoc y sin objetivos vinculantes
- ☐ No, aunque técnicamente sería posible
- ☐ No y no está previsto

3.1.2 En el caso de medir MTTD, ¿cómo lo calcula principalmente?

- ☐ Desde el momento de ocurrencia técnica del evento hasta su primera alerta en SIEM
- ☐ Desde la primera alerta en SIEM hasta la apertura de incidente en el sistema de ticketing
- ☐ Combinación de ambos (se registran ambos hitos)
- ☐ No está claramente definido

3.1.3 ¿Existe un objetivo formal de MTTD para incidentes de criticidad alta?

- ☐ Sí, < 15 minutos
- ☐ Sí, 15–60 minutos
- ☐ Sí, > 60 minutos
- ☐ No, sin objetivo formal
- ☐ No aplica / no medimos criticidad

3.1.4 ¿Mide formalmente su organización el MTTR (Mean Time To Respond / Recover)?

- ☐ Sí, hasta contención
- ☐ Sí, hasta resolución completa
- ☐ No, aunque se podría
- ☐ No, ni se plantea de momento

3.1.5 ¿Segrega su organización los tiempos MTTD/MTTR por tipo de incidente (ransomware, fraude, exfiltración, etc.) y por criticidad?

- ☐ Sí, sistemáticamente
- ☐ Parcialmente, en los incidentes más graves
- ☐ No, se manejan tiempos agregados
- ☐ No lo sabemos

3.2 Calidad (falsos positivos, alertas útiles)

3.2.1 ¿Mide la tasa de falsos positivos del SIEM?

- ☐ Sí, y se revisa al menos mensualmente
- ☐ Sí, pero de forma esporádica
- ☐ No, aunque sería deseable
- ☐ No, y no se considera prioritario

3.2.2 Aproximadamente, ¿qué porcentaje de alertas del SIEM se convierten en incidentes confirmados?

- ☐ < 5 %
- ☐ 5–10 %
- ☐ 11–20 %
- ☐ 21–30 %
- ☐ > 30 %
- ☐ Desconocido / no medido

3.2.3 ¿Monitoriza KPIs como “alertas descartadas sin análisis” o “errores de correlación”?

- ☐ Sí, ambos
- ☐ Sí, algunos (especificar): ____

- ☐ No, pero estamos trabajando en ello
- ☐ No se consideran relevantes de momento

3.2.4 ¿Mide la carga de trabajo de los analistas de SOC en términos de alertas o casos por persona y día?

- ☐ Sí, y ajustamos la automatización / staffing en función de ello
- ☐ Sí, pero sin impacto claro en decisiones
- ☐ No, aunque sería interesante
- ☐ No, y no está en la agenda

3.3 Cobertura (activos, técnicas, latencia)

3.3.1 ¿Dispone de un inventario de activos críticos alineado con el ENS / NIS2 y conectado con el SIEM?

- ☐ Sí, y se actualiza de forma automatizada
- ☐ Sí, pero la actualización es manual
- ☐ Inventario parcial o desalineado
- ☐ No disponemos de un inventario fiable

3.3.2 ¿Qué porcentaje aproximado de técnicas relevantes del marco MITRE ATT&CK para su sector está cubierto por casos de uso (reglas, detecciones) en el SIEM?

- ☐ 0–20 %
- ☐ 21–40 %
- ☐ 41–60 %
- ☐ 61–80 %
- ☐ 81–95 %
- ☐ > 95 %
- ☐ No lo sabemos / no usamos MITRE ATT&CK

3.3.3 ¿Mide el retraso medio de ingesta de eventos críticos (latencia desde ocurrencia hasta correlación en SIEM)?

- ☐ Sí, con objetivo < 1 minuto
- ☐ Sí, con objetivo 1–5 minutos
- ☐ Sí, pero sin objetivo definido
- ☐ No, no se mide

3.3.4 ¿Controla errores de parsing o pérdidas de datos (eventos no indexados, truncados, etc.) como KPI de calidad de ingesta?

- ☐ Sí, con alarmas y seguimiento formal
- ☐ Sí, pero solo en incidentes graves
- ☐ No, solo si alguien se queja
- ☐ No, asumimos que todo entra bien

4. Cumplimiento normativo y reporting (NIS2, ENS, DORA, etc.)

4.1 ¿Está su organización sujeta a NIS2 como entidad esencial o importante?

- ☐ Sí, esencial

- ☐ Sí, importante
- ☐ No
- ☐ No estoy seguro

4.2 ¿Utiliza el SIEM como fuente principal de evidencia para cumplir obligaciones de notificación de incidentes (NIS2, ENS, sectoriales)?

- ☐ Sí, el SIEM genera directamente los informes técnicos para el regulador / CERT
- ☐ Sí, pero combinado con otras herramientas
- ☐ Parcialmente, el SIEM solo proporciona datos brutos
- ☐ No, los informes se elaboran de forma manual / ad-hoc

4.3 En incidentes notificados a autoridades (INCIBE-CERT, CCN-CERT, reguladores sectoriales), ¿dispone de KPIs como:

- Tiempo desde detección a notificación
- Porcentaje de incidentes notificados dentro de plazo legal
- Grado de completitud de la evidencia adjunta (logs, timeline, IoC)
- ☐ Sí, todos
- ☐ Sí, algunos (especificar): ____
- ☐ No, pero se podría instrumentar
- ☐ No, y no está previsto

4.4 ¿Existe un mapeo formal entre casos de uso / reglas del SIEM y controles ENS / ISO 27001 / NIS2 / DORA aplicables?

- ☐ Sí, documentado y mantenido
- ☐ Sí, pero incompleto o desactualizado
- ☐ No, pero se está trabajando en ello
- ☐ No, y dependemos de interpretaciones puntuales

4.5 ¿Dispone su organización de métricas que vinculen el desempeño del SIEM con los requisitos de continuidad de negocio y resiliencia (por ejemplo, RTO/RPO, servicios esenciales, impacto)?

- ☐ Sí, con indicadores específicos por servicio crítico
- ☐ Sí, pero de forma indirecta / cualitativa
- ☐ No, todavía no
- ☐ No, y no se considera prioridad

5. IA, automatización y SOC moderno

5.1 ¿Utiliza el SIEM (o plataforma integrada XDR/SOC) capacidades de IA / analítica avanzada (UEBA, ML, scoring de riesgo, etc.)?

- ☐ Sí, extensivamente en producción
- ☐ Sí, en piloto o ámbitos reducidos
- ☐ Se dispone técnicamente, pero apenas se usa
- ☐ No, aún no

5.2 ¿Mide KPIs específicos de estas capacidades de IA, como:

- Porcentaje de detecciones impulsadas por modelos de IA
- Tasa de falsos positivos de modelos de IA
- Reducción de volumen de alertas tras su despliegue
- ☐ Sí, los tres
- ☐ Sí, algunos (especificar): ____
- ☐ No, solo miramos “si parece que funciona”
- ☐ No se aplica (no usamos IA)

5.3 ¿Dispone de plataforma SOAR o automatización de respuesta integrada con el SIEM?

- ☐ Sí, con playbooks desplegados en producción
- ☐ Sí, pero en fase inicial / piloto
- ☐ No, pero está planificado en los próximos 2 años
- ☐ No, sin planes próximos

5.4 ¿Mide el porcentaje de incidentes resueltos parcial o totalmente mediante automatización (sin intervención manual completa)?

- ☐ Sí, y se utiliza como KPI de eficiencia
- ☐ Sí, pero solo a título informativo
- ☐ No, aunque sería útil
- ☐ No, y no se contempla

5.5 En términos de madurez general del SOC y SIEM, ¿cómo se auto-evalúa su organización en una escala 0-5?

- 0 = Sin capacidades significativas
- 5 = SOC avanzado, automatizado, integrado con riesgo y negocio
- Puntuación global percibida: ____

6. OT, IoT y ámbitos específicos

6.1 ¿Incluye su SIEM de forma sistemática la monitorización de entornos OT/ICS relevantes para su negocio (energía, transporte, industria, etc.)?

- ☐ Sí, de forma integral
- ☐ Sí, pero parcial / solo segmentos concretos
- ☐ Planificado, aún no desplegado
- ☐ No, y no se considera prioritario

6.2 ¿Dispone de métricas específicas para incidentes en OT, tales como tiempo de detección de anomalías en ICS, impacto en procesos físicos o número de incidentes OT de gravedad alta al año?

- ☐ Sí, y se reportan a la alta dirección
- ☐ Sí, pero a nivel técnico únicamente
- ☐ No, aunque los incidentes se gestionan igualmente
- ☐ No, no aplicable (no tenemos OT relevante)

6.3 Si dispone de redes 5G u otras infraestructuras avanzadas, ¿forma parte la telemetría asociada de la monitorización SIEM?

- ☐ Sí, completamente
- ☐ Parcialmente
- ☐ No, pero está previsto
- ☐ No aplica

7. Gestión del riesgo, métricas agregadas e impacto

7.1 ¿Dispone de indicadores que relacionen los datos del SIEM con el riesgo de negocio (por ejemplo, incidentes por servicio, impacto económico, etc.)?

- ☐ Sí, cuantitativos (frecuencia, impacto estimado, pérdidas evitadas)
- ☐ Sí, principalmente cualitativos
- ☐ No, el SIEM se percibe como herramienta técnica
- ☐ No, pero se está trabajando en esa dirección

7.2 ¿Calcula algún índice global de madurez o desempeño de monitorización (IGM u otros) a partir de sus KPIs SIEM?

- ☐ Sí, con fórmula definida y revisada
- ☐ Sí, pero de forma informal / experimental
- ☐ No, aunque sería de interés
- ☐ No, y no está entre las prioridades

7.3 ¿Utiliza los datos del SIEM para justificar decisiones de inversión (ROI de proyectos de seguridad, priorización de iniciativas, etc.)?

- ☐ Sí, con análisis de ROI cuantitativo (ahorros, evitar pérdidas, etc.)
- ☐ Sí, principalmente con argumentos cualitativos
- ☐ Raramente, el SIEM se ve como “coste hundido”
- ☐ No, no se utiliza en ese contexto

7.4 ¿Participan las áreas de riesgo, auditoría y negocio en la definición de métricas SIEM que quieren ver en cuadros de mando?

- ☐ Sí, con gobernanza formal (comités, acuerdos de KPIs)
- ☐ Sí, de forma ocasional / puntual
- ☐ No, es un diseño principalmente del área técnica
- ☐ No, y no se considera necesario

8. Ecosistema nacional y colaboración

8.1 ¿Comparte métricas agregadas (no datos sensibles) con CERT nacionales (INCIBE-CERT, CCN-CERT) u otras plataformas de intercambio de información?

- ☐ Sí, periódicamente
- ☐ Sí, pero solo en incidentes concretos
- ☐ No, por falta de acuerdos / mecanismos
- ☐ No, por motivos de confidencialidad / política interna

8.2 ¿Utiliza referencias de ENISA, NCSI u otros índices internacionales para comparar su desempeño SIEM/SOC con el de otros países u organizaciones?

- ☐ Sí, activamente
- ☐ Ocasionalmente
- ☐ No, aunque tenemos interés
- ☐ No, no lo consideramos relevante

9. Preguntas abiertas (para los espíritus creativos)

9.1 ¿Cuál considera que es la principal fortaleza de su organización en monitorización y gestión de eventos (SIEM/SOC)?

Respuesta abierta

9.2 ¿Cuál es la principal debilidad o dolor de cabeza que le gustaría poder resolver en los próximos 12–24 meses?

Respuesta abierta

9.3 Si pudiera introducir una única métrica nueva en su cuadro de mando SIEM que realmente cambiara la conversación con la dirección, ¿cuál sería y por qué?

Respuesta abierta

9.4 Cualquier comentario adicional que quiera compartir sobre el uso de métricas SIEM para mejorar la ciberseguridad nacional, la cooperación con otros actores o el cumplimiento regulatorio:

Respuesta abierta